PARABELLUM IO — GRC COMPLIANCE DASHBOARD

Security & Compliance Audit Report

GRC-2026-7928

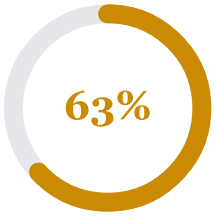
project2-nodejs-todo.zip

CONDITIONAL PASS | Score: 63% | Tier 2 — Risk-Informed

NIST CSF 2.0

Generated	Prepared By	Platform	Classification
13/05/2026, 23:00:43	Mirza Fahad Raza	SonarQube SAST	CONFIDENTIAL

2. Executive Summary



Compliance Score

CONDITIONAL PASS

⚠ CONDITIONAL PASS — remediation required within 30 days.

The project2-nodejs-todo.zip pipeline was assessed against the NIST CSF 2.0 standard.0 issues were analyzed across 2 unique CWE weaknesses, producing an audit score of **63%**.

NIST CSF Maturity Tier	**Tier 2 — Risk-Informed**
Overall Audit Score	**63/100**
Total Issues Scanned	**0**
Unique CWE Weaknesses	**2**
Critical	**1**
High	**0**
Medium	**1**
Low	**0**
Overall Risk Score	**2.7 / 10**

3. NIST CSF 2.0 Function Breakdown

GV — GOVERN	ID — IDENTIFY	PR — PROTECT
100%	100%	72%
PASS	PASS	WARN

DE — DETECT	RS — RESPOND	RC — RECOVER
90%	100%	100%
WARN	PASS	PASS

3b. Control Mapping — CWE Technical Findings

CWE ID	VULNERABILITY	CVSS	SEVERITY	POSSIBLE ATTACKS	ISSUES	RISK IMPACT
CWE-798	**Use of Hard-coded Credentials**	9.1	Critical	Authentication Bypass, Credential Theft	1	Hard-coded passwords or API keys embedded in source code can be extracted by anyone with a...
CWE-693	**Protection Mechanism Failure**	5.0	Medium	Security Control Bypass, Unspecified Exploitation	1	A general weakness in security mechanisms that may allow various forms of exploitation dep...

4. Failed NIST Controls

PR.DS-01 **Data-at-rest is protected.** FAIL

[CRITICAL] [POL-S02] Potential hardcoded secret found.

DE.CM-08 Vulnerabilities in assets are identified and communicated to applicable teams. FAIL

[HIGH] [POL-C02] Base image uses 'latest' or unspecified version tag.

PR.IP-01 A baseline configuration of IT/ICS systems is created and maintained. FAIL

[HIGH] [POL-C02] Base image uses 'latest' or unspecified version tag.

4b. Governance & Policy Alignment

NIST FUNCTION	SCORE	STATUS	KEY CONTROLS	RECOMMENDED ACTION
GOVERN	100%	PASS	GV.RM-01, GV.OC-01	Establish risk governance policies and assign ownership.
IDENTIFY	100%	PASS	ID.AM-01, ID.RA-01	Complete asset inventory and risk assessment.
PROTECT	72%	WARN	PR.DS-01, PR.AA-01	Enforce least-privilege, patch management, and encryption.
DETECT	90%	WARN	DE.CM-01, DE.CM-08	Deploy SIEM and continuous vulnerability scanning.
RESPOND	100%	PASS	RS.MA-01, RS.AN-01	Document and test incident response playbooks.
RECOVER	100%	PASS	RC.RP-01	Define recovery time objectives (RTO/RPO) and test backups.

5. Detailed Findings & Remediation

CWE-798 Use of Hard-coded Credentials

Critical CVSS 9.1

Hard-coded passwords or API keys embedded in source code can be extracted by anyone with access to the codebase, granting full unauthorized access.

T1552 T1078 A07:2021 CAPEC-191

1 issue · 1 file · Est. effort: **1 day**

Remediation: Store credentials in environment variables or a secrets manager (e.g., HashiCorp Vault, AWS Secrets Manager). Rotate any exposed credentials immediately.

CWE-693 Protection Mechanism Failure

Medium CVSS 5

A general weakness in security mechanisms that may allow various forms of exploitation depending on the specific context.

T1562 A05:2021 CAPEC-122

1 issue · 1 file · Est. effort: **1 hour**

Remediation: Review security controls. Apply defense-in-depth. Follow secure coding guidelines.

6. Compliance Gap Matrix

CONTROL AREA	NIST CSF	STATE	GAP	PRIORITY
Access Control	PR.AA-01	Partial	PROTECT score 72% — requires improvement	P2 High
Data Security	PR.DS-01	Partial	PROTECT score 72% — requires improvement	P2 High
Vulnerability Mgmt	DE.CM-08	Implemented	Meets baseline	P3 Medium
Secure Coding	PR.PS-01	Partial	PROTECT score 72% — requires improvement	P2 High
Logging & Monitoring	DE.CM-01	Implemented	Meets baseline	P3 Medium
Incident Response	RS.MA-01	Implemented	Meets baseline	P3 Medium
Risk Governance	GV.RM-01	Implemented	Meets baseline	P3 Medium

CONTROL AREA	NIST CSF	STATE	GAP	PRIORITY
Asset Management	ID.AM-01	Implemented	Meets baseline	P3 Medium

⚠️ 7. Risk Register

RISK ID	DESCRIPTION	LIKELIHOOD	IMPACT	SCORE	OWNER	STATUS	TARGET DATE
RISK-001	CWE-798: Use of Hard-coded Credentials (1 issues)	5	5	25	Security Team	Open	20/05/2026 (7d)

8. Audit Attestation

Report ID	GRC-2026-7928
Report Date	13/05/2026, 23:00:43
Project Name	project2-nodejs-todo.zip
Project Key	project2-nodejs-todo.zip
CI/CD Platform	SonarQube SAST Integration
Tools Used	SonarQube (SAST), CWE Database, NIST CSF 2.0 Mapping Engine
Scan Coverage	0 issues, 2 CWEs, 3 failed controls
Frameworks Assessed	NIST CSF 2.0
Overall Verdict	CONDITIONAL PASS
Report Generation	Auto-generated by GRC Compliance Dashboard
Prepared By	Mirza Fahad Raza

⚠️ **Disclaimer:** This report is machine-generated evidence supporting human audit review. It is not a substitute for a formal third-party audit. Results are based on static analysis and automated CWE/NIST mapping. Manual review by a qualified security professional is recommended before using this report for regulatory compliance purposes.

GRC-2026-7928 · project2-nodejs-todo.zip · CONFIDENTIAL